

Practical 8

Vulnerability Assessment Report

1. Aim

To systematically identify, quantify, and prioritize security vulnerabilities within a target network/system using an automated vulnerability scanner (Nessus), and to generate a comprehensive assessment report outlining remediation strategies.

2. Objectives

- Deploy and configure the Nessus vulnerability scanner on a Kali Linux environment.
- Execute an authenticated/unauthenticated "Basic Network Scan" against a vulnerable target VM.
- Interpret the scan results, filtering out false positives and categorizing threats by severity (CVSS score).
- Prepare a detailed vulnerability report comprising findings, risk impacts, and actionable recommendations.
-

3. Tools Used

- **Vulnerability Scanner:** Tenable Nessus Essentials.
- **Attacker/Auditor OS:** Kali Linux.
- **Target System:** Metasploitable 2 VM (Purpose-built vulnerable Linux host).

4. System Requirements

- Kali Linux VM with an active Nessus installation (requires browser access to localhost port 8834).
- Target VM configured on the same Host-Only or NAT network (IP Address: 192.168.56.102).

5. Theory

Vulnerability Assessment (VA): The systematic process of evaluating security weaknesses in an information system. Unlike penetration testing (which involves actively exploiting vulnerabilities), VA focuses purely on identifying, quantifying, and prioritizing vulnerabilities based on the Common Vulnerability Scoring System (CVSS).

Nessus: Developed by Tenable, Nessus is one of the most trusted vulnerability scanners in the cybersecurity industry. It uses a vast database of plugins to check for misconfigurations, missing patches, default passwords, and known software flaws across various operating systems and services.

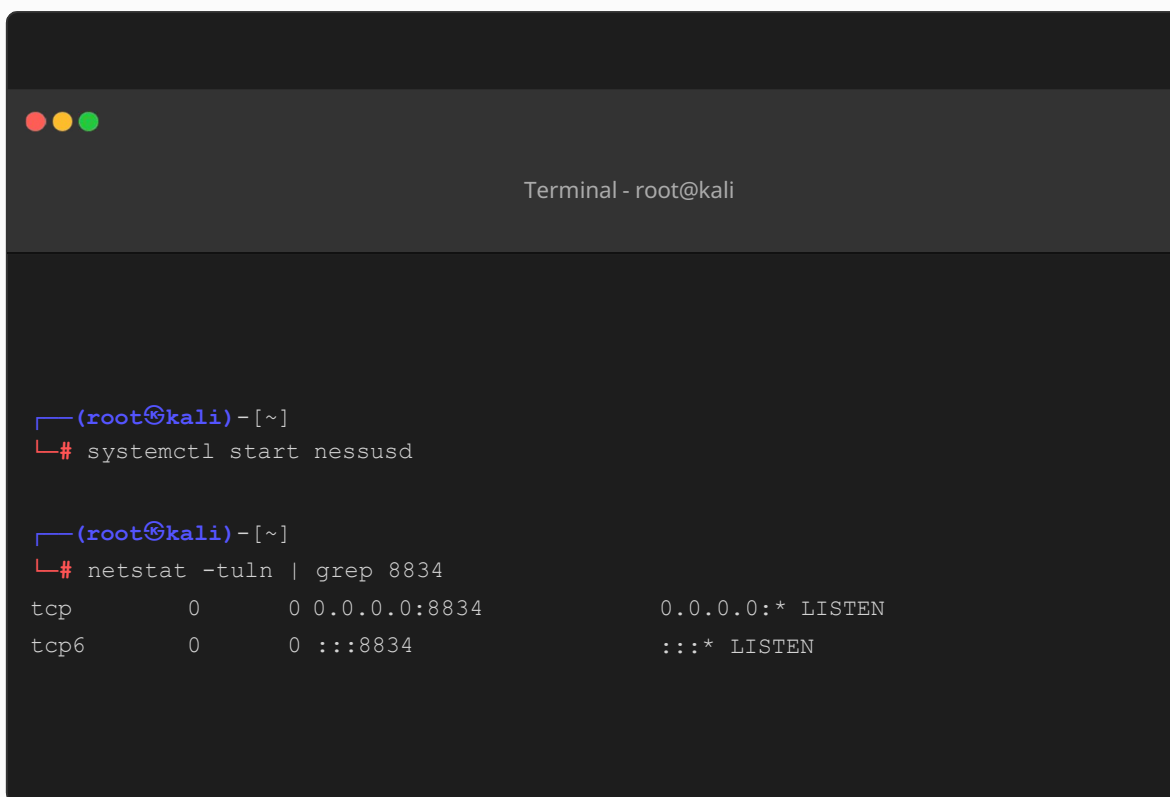
6. Lab Setup

The assessment is conducted in a completely isolated virtual lab environment. The Nessus daemon runs on the Kali VM, and the target is a Metasploitable 2 instance known to harbor various unpatched services.

7. Procedure & Attack Flow

Step 1: Starting the Nessus Service

First, we initiate the Nessus daemon service via the command line on the Kali Linux host and verify it is listening on the default port 8834.

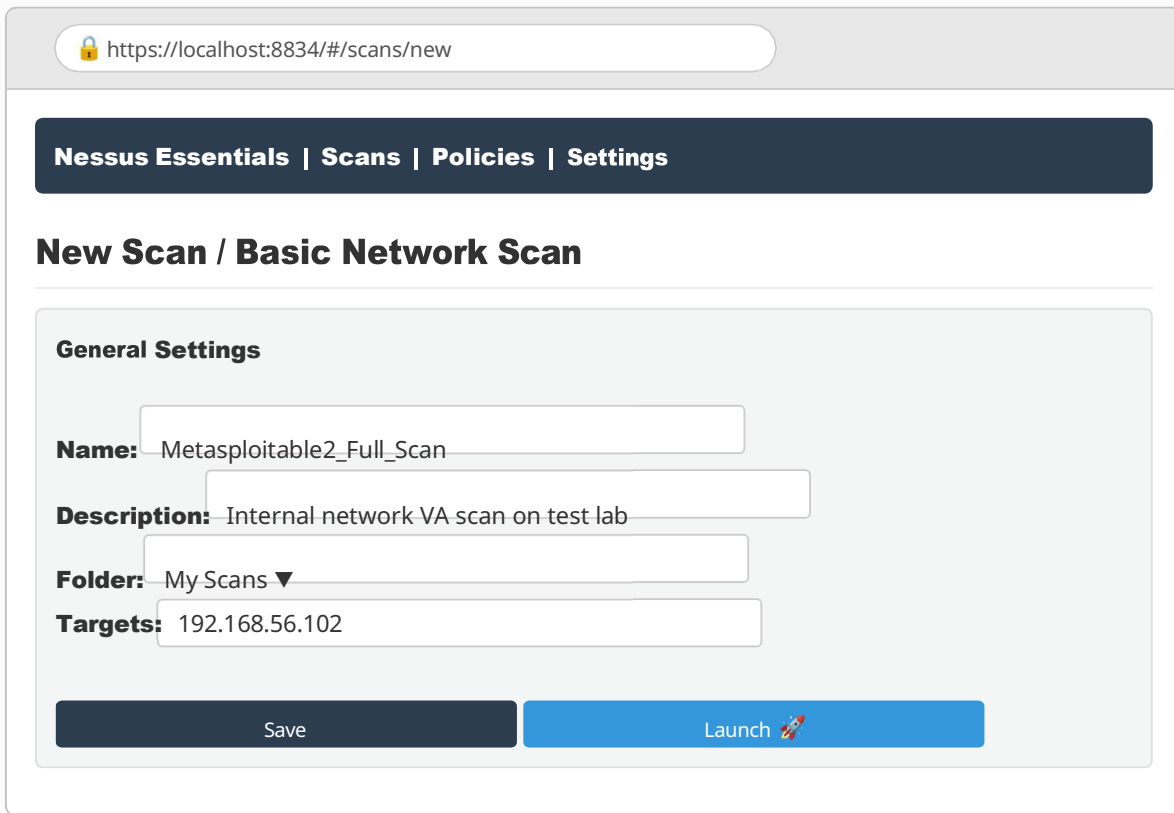
A terminal window titled "Terminal - root@kali" with a dark background. It shows two commands being executed. The first command is "systemctl start nessusd". The second command is "netstat -tuln | grep 8834", which returns two lines of output: "tcp 0 0 0.0.0.0:8834 0.0.0.0:* LISTEN" and "tcp6 0 0 :::8834 :::* LISTEN".

```
(root@kali) ~  
# systemctl start nessusd  
  
(root@kali) ~  
# netstat -tuln | grep 8834  
tcp        0      0 0.0.0.0:8834      0.0.0.0:* LISTEN  
tcp6       0      0 :::8834          :::* LISTEN
```

Screenshot 1: Starting the Nessus daemon and verifying the listening port

Step 2: Accessing the Web Interface and Configuring the Scan

We access the Nessus web interface via the browser, log in, and create a new "Basic Network Scan". We define the scan name and input the target IP address (192.168.56.102).



The screenshot displays the Nessus web interface for creating a new scan. The browser address bar shows `https://localhost:8834/#/scans/new`. The navigation bar contains links for **Nessus Essentials**, **Scans**, **Policies**, and **Settings**. The main heading is **New Scan / Basic Network Scan**. Below this, the **General Settings** section contains the following fields:

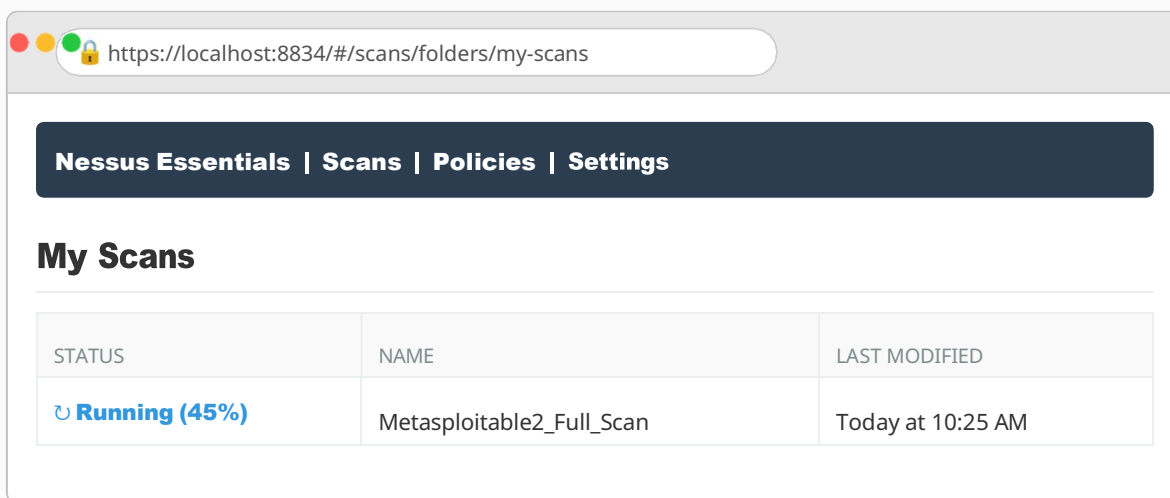
- Name:** Metasploitable2_Full_Scan
- Description:** Internal network VA scan on test lab
- Folder:** My Scans ▼
- Targets:** 192.168.56.102

At the bottom of the settings section are two buttons: **Save** and **Launch** (with a rocket icon).

Screenshot 2: Configuring the Basic Network Scan targeting the vulnerable VM

Step 3: Scan Execution and Progress Monitoring

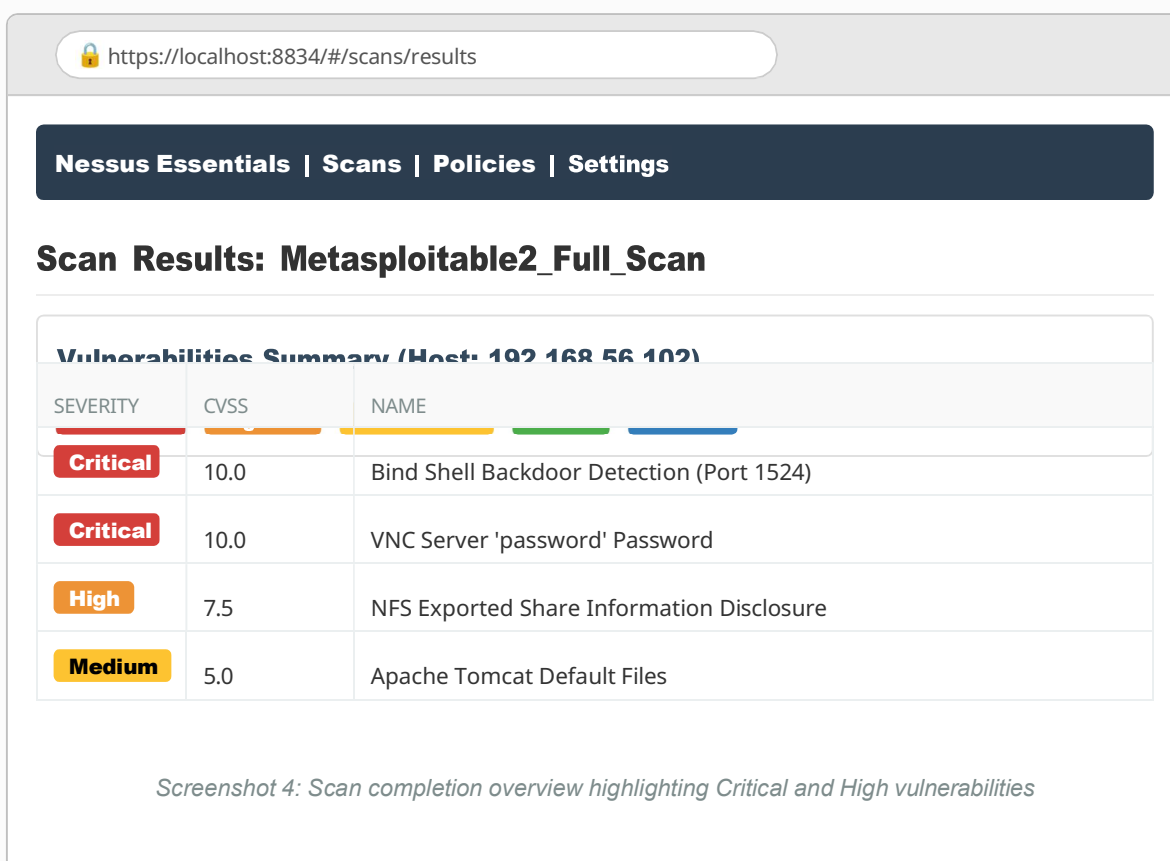
The scan is launched. Nessus systematically probes the target's open ports, enumerates running services, and matches banner/response data against its plugin database to identify vulnerabilities.



Screenshot 3: Monitoring the active scan progress

Step 4: Scan Results and Executive Summary

Upon completion, Nessus generates an overview dashboard categorizing the findings by severity. The scan indicates severe systemic compromise potential on the target host.



Screenshot 4: Scan completion overview highlighting Critical and High vulnerabilities

Step 5: Analyzing Specific Vulnerability Details

Clicking on individual vulnerabilities provides a detailed breakdown, including the description, the specific port affected, and the recommended remediation strategy.

 https://localhost:8834/#/scans/results/vulnerability

Critical

Bind Shell Backdoor Detection

Description: A shell is listening on the remote port without requiring any authentication. An attacker may use it to gain a command prompt on the remote system with the privileges of the running service.

Solution: Verify if the system has been compromised and reinstall the operating system if necessary. Alternatively, disable the service or restrict access via a firewall.

Plugin Output:

```
Nessus was able to open a shell on the remote host:
Port: 1524 / tcp
Output: root@metasploitable:/# uid=0(root) gid=0(root) groups=0(root)
```

Screenshot 5: Detailed analysis of the "Bind Shell Backdoor" critical finding

8. Key Findings & Recommendations Report

Based on the Nessus scan output, the following high-priority issues were identified on the target host (192.168.56.102):

Vulnerability	Severity	Impact	Recommendation / Remediation
Bind Shell Backdoor	Critical	Port 1524 is open and providing an unauthenticated root-level command shell directly to the network.	Immediate system quarantine. Since a root shell is active natively, the system must be considered fully compromised. Rebuild the system from a clean image.
	Critical	The VNC server is configured with a weak password ('password'),	Update the VNC configuration to use strong, complex authentication or disable the
VNC Weak Password	High	allowing arbitrary remote desktop access.	VNC service entirely if it is not required for business operations.

vsftpd 2.3.4 Backdoor	The running FTP service contains a malicious backdoor triggered by specific usernames, leading to remote code execution.	Upgrade vsftpd to the latest stable version. Implement strict firewall rules to restrict FTP access to authorized administrative IP addresses only.
----------------------------------	--	---

9. Observations

- The target system is running multiple outdated and inherently insecure services designed for lab testing.
- Automated scanners like Nessus accurately identify known CVEs and misconfigurations by comparing network responses against comprehensive vulnerability signatures.
- No actual exploitation occurred during the scan; the scanner merely validated the presence of the vulnerabilities (e.g., verifying the VNC password).

10. Limitations

- **False Positives:** Automated scanners may occasionally flag vulnerabilities based on banner grabbing without verifying if a backported patch has been applied by the OS vendor.
- **Impact on Target:** Aggressive scanning policies can sometimes crash fragile legacy services or consume significant network bandwidth.

11. Precautions

- Always obtain explicit, written authorization before running any vulnerability scanner against a network or host.
- Schedule scans during off-peak hours to minimize the impact of network traffic generation on production systems.

12. Conclusion

This practical lab successfully demonstrated the core workflow of conducting a Vulnerability Assessment. By deploying Nessus, scanning the target, and interpreting the generated dashboard data, we identified critical security flaws including active backdoors and weak credentials. This exercise underscores the necessity of continuous vulnerability management and proper patch implementation to secure organizational infrastructure against external threats.